

Quantified Treatment Investment Memorandum

To: Advanced Assessment Panel

From: Chizaram Precious Patrick, GRC Analyst

Intern reference: UBI-2026-0099, track GRC, private assignment set D5

Evidence marker: UBI-A8-0725D08E95BE

Date: 2026-08-19

Subject: Allocation of the USD 85,000 security treatment budget

1. Decision

Three risks are recommended for treatment at a combined cost of USD 73,000 out of the available USD 85,000 budget. Based on the model, these treatments reduce the mean annual residual loss by USD 1,879,861.

Risk	Finding	Asset	Cost (USD)	Modelled reduction (USD)	Return per USD
R-006	VF-006	backup-01	22,000	1,075,830	48.9
R-002	VF-002	payroll-api-01	45,000	502,054	11.2
R-008	VF-008	idp-01	6,000	301,976	50.3
		Total	73,000	1,879,861	25.8

The remaining nine risks are deferred, but they are not being ignored. Each one has a named accountable owner, an acceptance authority, a target date, and a review trigger.

The main point that may attract attention is that this decision is not based on CVSS severity alone. Two findings with a CVSS score of 9.8 Critical are deferred, while the lowest-scored finding in the export, with a score of 4.3, is treated. The reason for this is explained in Section 5.

2. How the numbers were produced

The figures in this memorandum are reproducible from the submitted repository. The model is deterministic, meaning that the same inputs produce the same results on any supported host.

For the simulation, Python 3.11.9 and NumPy 2.1.3 were used with `numpy.random.Generator(PCG64)`. Each risk was simulated using exactly 50,000 draws. The seed is generated from the first unsigned 64 bits of

SHA-256(evidence_marker + ":GRC-A4"), read in big-endian format. For this assignment, the seed is 512818773672660033.

The risk rows are first sorted into a canonical order before the draws are made. Meaning the results do not change simply because the rows appear in a different order in the input file.

For each risk and each draw, annual event frequency is sampled from a triangular distribution, loss magnitude is sampled from a triangular distribution, and control effectiveness is sampled from a uniform distribution. Inherent loss is then calculated using frequency, loss magnitude, and the dependency multiplier. Residual loss is the inherent loss after applying the sampled control effectiveness.

For treatment pricing, each treatment defines the control effectiveness range expected after implementation. The model then simulates the risk twice: once using the baseline control and once using the treated control. Both simulations use the same seed and row ordering, so the frequency and loss draws remain the same. This allows the difference in mean residual loss to reflect the effect of the treatment instead of sampling noise.

For selection, the optimiser checks every possible combination of three treatments. Any combination that exceeds the budget or has an unsatisfied dependency is removed. The remaining combinations are compared based on total mean residual-loss reduction. Where two portfolios differ by less than one cent, the lexicographically smaller ordered treatment-ID list is selected.

This approach was used instead of choosing the highest return per dollar because dependency constraints can make a greedy approach give the wrong result.

The model parameters were derived from the evidence in the export. Frequency ranges use the `exploit_evidence` values and place findings into four tiers: weaponised, demonstrated, conditional, and inferred. An environment factor is then used to reduce reachability for test, office, and quarantine environments.

Loss ranges are based on each asset's annual revenue dependency at 1, 5, and 20 percent, with a sublinear adjustment for record volume. Control effectiveness is based on whether the existing control actually addresses the specific weakness identified. Dependency multipliers above 1.0 are only used where other systems depend on or route through the affected asset.

The full derivation for each risk is included in the `rationale` field in `risk-model/input/model-input.json`, while the register records the related control weakness and business consequence.

3. Why loss is anchored to revenue rather than record count

A record-count approach was considered but rejected.

IBM's 2025 Cost of a Data Breach report gives an example of intellectual property costing approximately USD 178 per record in certain breach categories. Applying that figure directly to the 920,000 records on files-01 would produce a figure of roughly USD 164 million. That

does not make sense when the same asset has a USD 1.8 million annual revenue dependency and the global average breach cost in the same report is USD 4.44 million.

The issue is that breach costs do not increase linearly with the number of records involved.

For this reason, the model anchors loss to annual revenue dependency and uses record volume only as a bounded modifier. Using this approach, the largest single-finding maximum loss is USD 2.1 million on the identity provider. This keeps the model within the range of the published average while also keeping the estimates internally consistent across all twelve findings.

4. The three treated risks

R-006 - Restrict the backup management interface to the management VLAN and require MFA

Cost: USD 22,000. Modelled reduction: USD 1,075,830. Inherent score: 12, the highest in the register.

backup-01 has the largest modelled inherent exposure in the estate at USD 1,288,821.

There are three main reasons for this. First, it is a crown-jewel asset holding 920,000 records and carrying USD 5.2 million in revenue dependency. Second, its management interface was validated as reachable from the user VLAN. Third, the only control protecting that interface is password authentication, which does not remove the network path that was already demonstrated.

There is also a dependency multiplier above 1.0 because compromising the backup coordinator affects the recovery path for the other assets. This increases the possible impact of a separate incident.

The proposed treatment removes the validated network path and adds a second authentication factor. Both controls directly address the weakness. After treatment, the residual score falls from 12 to 3.

R-002 - Enforce server-side object authorization on the payroll API

Cost: USD 45,000. Modelled reduction: USD 502,054.

This is the most expensive treatment being funded and it has the lowest return per dollar among the three selected treatments.

It is still being funded because the weakness was demonstrated rather than inferred. A cross-tenant read was validated on a crown-jewel asset containing 18,400 records and carrying USD 4.2 million in revenue dependency.

The existing controls show why control effectiveness has to be assessed against the actual weakness. The WAF can inspect request patterns, while authentication confirms the identity

of the user. Neither of these controls performs the missing server-side authorization check. In the validated scenario, the attacker is already authenticated.

Because of this, existing control effectiveness is modelled at only 0.05 to 0.20 even though both controls are real and may work properly for the problems they were designed to address.

The USD 45,000 cost reflects the application development and regression testing required across the payroll system. In this case, the cost is based on actually fixing the authorization model rather than trying to filter around the weakness.

The residual score falls from 9 to 3.

R-008 - Reduce the privileged session lifetime on the identity provider

Cost: USD 6,000. Modelled reduction: USD 301,976. Best return in the estate.

VF-008 has the lowest CVSS score in the entire export at 4.3, but it is treated ahead of every High and Critical finding.

The reason is exposure, not the severity label.

idp-01 is the identity provider and is therefore a crown-jewel asset. It holds 18,400 records and has USD 8.1 million in annual revenue dependency, which is the highest in the estate. It also has a dependency multiplier of 1.5 because the federated systems trust its identity assertions.

This means that a compromise would not be limited to the identity provider itself.

Phishing-resistant MFA is already a strong control and is therefore given meaningful effectiveness in the model, at 0.35 to 0.60. MFA reduces the chance of an attacker obtaining an administrator session in the first place. However, it does not shorten the lifetime of a session after it has already been established.

That is the specific gap this treatment addresses.

At USD 6,000, this is the best return per dollar available. It does not require new technology; it requires enforcement of an existing security policy through a session-policy configuration change.

The residual score falls from 8 to 2, which is the lowest residual position among the three treated risks.

5. Why both Critical findings are deferred

VF-001 and VF-007 are both scored CVSS 9.8 Critical, and both have public exploit information available. Despite this, both are deferred.

This is probably the part of the recommendation most likely to be challenged, so the reasoning needs to be clear.

	VF-001 edge-lab-07	VF-007 marketing-old
CVSS v3	9.8 Critical	9.8 Critical
Exploit evidence	Public exploit listed	PoC available
Asset criticality	Low	Low
Environment	Test	Quarantine
Records held	0	0
Annual revenue dependency	USD 0	USD 0
Existing controls	Isolated test subnet	No DNS, egress blocked
Modelled inherent ALE	USD 4,469	USD 1,787
Inherent score	4	3
Modelled reduction if treated	USD 3,174	USD 738
Rank by reduction	10th of 12	12th of 12

CVSS tells us how severe a vulnerability is in simple terms: how easily it can be exploited and how serious the compromise of the affected component could be. It does not consider what that particular component means to the business.

In this case, both assets hold no records and support no revenue.

VF-001 is an ephemeral QA scanner located on an isolated test subnet. VF-007 is a retired content management system kept in quarantine, with no DNS resolution and blocked egress. These controls specifically reduce the callback and lateral-movement paths that a remote code execution payload would normally depend on.

The model still gives both findings relatively high frequency estimates because public exploit code can attract opportunistic scanning. The important difference is the consequence. A high probability combined with a near-zero business loss still produces a low annual loss expectancy.

The comparison with R-008 makes this clearer. R-008 produces 409 times the modelled reduction of VF-007 and 95 times the reduction of VF-001.

Treating either Critical finding before the identity provider would therefore mean spending the budget based mainly on the most alarming severity label rather than on the largest exposure.

Both findings remain on the register. They still have owners, acceptance authorities, and review triggers.

VF-007 should also be removed after the evidence hold is completed. Its destruction is estimated at USD 1,500. That should be treated as routine security hygiene rather than because it ranks highly in the risk model.

A related distinction: VF-003

VF-003 has a CVSS score of 8.8 High on the remote access gateway. It is an important asset, but it is still deferred and ranks 8th of 12.

The reason is the quality of the evidence.

Its exploit evidence is listed as "version match only". The finding was inferred from a banner and was not demonstrated on this estate. This is materially weaker than the validated findings that were selected for treatment.

The model therefore places VF-003 in the lowest frequency tier.

This is a deferral pending better evidence, not a statement that the risk is unimportant. If exploitation is demonstrated on the appliance, the finding should move out of the inferred tier and its ranking should be reassessed.

The recommended next step is therefore to confirm whether the vulnerability is actually present before committing the USD 8,000 upgrade cost.

6. Sensitivity

The assignment requires the annual-loss estimates to be tested using a 30 percent uncertainty band.

The full model, including simulation, treatment pricing, and portfolio selection, was rerun with every loss range scaled to 0.70 and 1.30 of its original estimate.

Case	Treated portfolio
Low (0.70x)	R-002, R-006, R-008
Base (1.00x)	R-002, R-006, R-008
High (1.30x)	R-002, R-006, R-008

The selection remains the same across the entire uncertainty band.

This means the decision does not depend on having perfect loss estimates. Even if the estimates are wrong by 30 percent in either direction across all findings, the three selected risks remain the same.

The absolute loss figures still have uncertainty, as any forward-looking estimate will. What is more important here is that the ranking remains stable.

The `ale_low_usd` and `ale_high_usd` columns in the register represent the edges of this uncertainty band. They should not be interpreted as independently elicited estimates.

7. Unspent budget

There is USD 12,000 remaining from the USD 85,000 budget.

The assignment requires exactly three treatments. No other permitted combination of three treatments produces a greater total reduction, and there is no cheaper substitution that improves the selected outcome.

The remaining USD 12,000 should therefore not be spent simply because it is available.

There are two reasonable options for the panel.

First, the money can be retained as contingency for R-002 because its USD 45,000 cost carries the most uncertainty. Application changes to a payroll system can easily exceed the initial estimate once implementation and regression testing begin.

Second, the money can support the evidence-gathering work for VF-003. Confirming whether the inferred vulnerability actually exists would provide better information for the next funding cycle.

8. Deferred risks and residual position

Risk	Finding	Asset	CVSS	Inherent	Residual	Cost (USD)	Owner	Acceptance authority
R-009	VF-009	dev-git-01	7.5	9	9	9,000	Platform Engineering Lead	CISO
R-003	VF-003	vpn-gw-01	8.8	6	6	8,000	Network Operations Lead	Head of IT Operations
R-004	VF-004	files-01	5.3	6	6	12,000	Infrastructure Lead	Head of IT Operations
R-005	VF-005	helpdesk-02	7.8	6	6	18,000	Endpoint Operations Lead	Head of IT Operations
R-010	VF-010	dns-01	5.3	6	6	4,000	Network Operations Lead	Head of IT Operations

R-001	VF-001	edge-lab-07	9.8	4	4	2,000	Infrastructure Lead	Head of IT Operations
R-011	VF-011	db-reporting	6.4	4	4	3,000	Database Operations Lead	Head of IT Operations
R-007	VF-007	marketing-old	9.8	3	3	1,500	Infrastructure Lead	Head of IT Operations
R-012	VF-012	print-03	7.4	2	2	2,500	IT Operations Lead	Head of IT Operations

Deferral does not change the inherent score because nothing has changed on the affected host. Deferral is a risk decision with an owner, an authority, a date, and a review trigger. It is not simply leaving the finding unattended.

R-009 deserves specific attention from the panel.

dev-git-01 has an inherent score of 9 and remains at 9 residual, making it the highest residual position in the register. It is also the only deferred risk requiring CISO acceptance.

An inactive deploy key was validated as still working, and that key provides a path into the production release process. At USD 9,000, R-009 is the strongest candidate for the next funding cycle.

It is being deferred here because the three selected treatments provide greater immediate value within the available budget.

There are also two low-cost items that should be handled through operational budgets outside this particular allocation.

R-011 should receive attention in particular because the TLS certificate on db-reporting expires in 12 days. Its modelled reduction is relatively small because the issue is primarily an availability risk rather than a confidentiality breach, but the event has a known date and is highly likely if nothing is done.

R-010 is also relatively inexpensive at USD 4,000 compared with its inherent score of 6 and should not necessarily wait for another major funding decision.

9. Residual risk

After implementing the three selected treatments, the modelled mean annual residual loss across the estate falls from USD 3,229,259 to approximately USD 1,349,398.60.

The remaining exposure is concentrated mainly in the deferred findings affecting crown-jewel and high-criticality assets.

The two findings that deserve the most attention are R-009 on dev-git-01, which remains at CISO acceptance level, and R-004 on files-01, which holds 920,000 customer records.

10. Limitations

There are some limitations to this recommendation, and they should be considered when reviewing the decision.

The loss method is a judgment. The 1, 5, and 20 percent fractions of annual revenue dependency are reasoned estimates based on published breach averages. They are not actual incident costs for this organisation. If actual incident cost data becomes available, it should replace these assumptions.

Control effectiveness is also based on assessment rather than measurement. The ranges reflect whether the existing controls address the specific weakness identified. Actual control testing evidence would provide a stronger basis for these values.

The frequency tiers are ordinal rather than actuarial. They rank findings according to the quality of their exploit evidence instead of being based on historical incident rates. This is reasonable for a twelve-finding export where there is no historical baseline, but it is also why the sensitivity analysis is more useful for the decision than treating the absolute numbers as exact.

Dependency multipliers are structural estimates. They represent the fact that compromise of assets such as the identity provider, DNS, and backup coordinator can affect other systems. The multiplier values are reasoned estimates and are not based on a formal dependency map.

The likelihood and impact scores are presentation bands. The 1-5 values in the register are derived from the modelled frequency and loss ranges using the stated thresholds. They are not a second, independent risk assessment.

The scan output is evidence, not certification. The before-and-after scanner results demonstrate configuration state at a particular point in time. They do not amount to compliance certification.

The biggest challenge to this memorandum would be evidence showing that the loss estimates are wrong by significantly more than 30 percent and, importantly, that the error is different across the findings. The sensitivity test addresses a uniform 30 percent error but does not address a situation where one asset's exposure has been significantly underestimated compared with another.

11. Recommendation

The panel is asked to approve treatment of R-002, R-006, and R-008 at a combined cost of USD 73,000.

The panel should also note the deferral of the remaining nine risks, with their owners, acceptance authorities, target dates, and review triggers recorded in `risk-register.csv`.

Particular attention should be given to R-009, which remains at inherent score 9 and requires CISO acceptance while it is deferred.

Prepared by: Chizaram Precious Patrick

Role: GRC Analyst

Evidence marker: UBI-A8-0725D08E95BE

Supporting artefacts: `risk-model/`, `risk-register.csv`,
`risk-model/output/treatment-selection.json`,
`risk-model/output/sensitivity.json`